SIMRS SaaS

RBAC & Permission Reference Guide

Dokumentasi lengkap:

- 11 Role dengan hak akses terperinci
- 38 Permission unik per modul
- 35+ Halaman & fitur yang dapat diakses
- Dual-layer security (Frontend + Backend)
- 13 Test account lengkap dengan password

VERSI	Versi 1.0
TANGGAL	7 November 2026
TENANT DEMO	rs-demo.simrs.online

CONFIDENTIAL — For Internal & Client Use Only

Daftar Isi

1. Overview Sistem RBAC 3

2. Daftar Role (11 Role) 3

3. Daftar Permission (38 Permission Unik) 4

4. Matriks Akses Role × Permission 6

5. Rincian Per Role — Menu & Fitur 7

5.1 Superadmin — SA Panel 7

5.2 Admin RS — Akses Penuh (38 Permission) 7

5.3 Dokter — Fokus Klinis (17 Permission) 8

5.4 Perawat — Asistensi Klinis (9 Permission) 8

5.5 Apoteker — Farmasi & Stok (7 Permission) 8

5.6 Kasir — Billing & Pembayaran (6 Permission) 8

5.7 Pendaftaran — Front Office (9 Permission) 8

5.8 Rekam Medis, Manajemen, Lab, Radiologi 9

6. Security Guard: Frontend & Backend 9

6.1 Frontend Guard (Menu Filtering) 9

6.2 Backend Guard (RBAC Middleware) 9

6.3 Alur Autentikasi & Session 9

7. Test Accounts — Tenant rs-demo 10

7.1 Super Admin (Platform Level) 10

7.2 Akun Tenant rs-demo (12 User) 10

7.3 Ringkasan Akses Per Akun 10

1. Overview Sistem RBAC

SIMRS SaaS mengimplementasikan Role-Based Access Control (RBAC) untuk mengatur hak akses pengguna secara granular. Sistem ini beroperasi pada dua level:

- **Platform Level** — Super Admin (owner/operator) mengelola seluruh tenant RS melalui SA Panel terpisah.
- **Tenant Level** — Setiap RS memiliki role internal (admin, dokter, perawat, dll) dengan permission masing-masing.

Setiap aksi di-guard pada dua lapisan: Frontend (menu di-filter berdasarkan role) dan Backend (middleware RBAC memeriksa permission sebelum endpoint dieksekusi).

11	38	35+	2
Role	Permission Unik	Halaman / Fitur	Layer Guard (Frontend + Backend)

2. Daftar Role (11 Role)

#	Nama Role	Level	Perm	Deskripsi
1	superadmin	Platform	7	Pengelola platform SaaS (owner/operator)
2	admin	Tenant	38	Administrator RS — akses penuh ke semua fitur
3	dokter	Tenant	17	Dokter — fokus klinis, rekam medis, resep
4	perawat	Tenant	9	Perawat — asistensi klinis, pengkajian
5	apoteker	Tenant	7	Apoteker — farmasi, stok, dispensing obat
6	kasir	Tenant	6	Kasir — billing & pembayaran
7	pendaftaran	Tenant	9	Front office — registrasi pasien & antrian
8	rekam_medis	Tenant	5	Petugas RM — arsip rekam medis
9	manajemen	Tenant	7	Pimpinan RS — laporan & statistik
10	lab	Tenant	4	Petugas laboratorium
11	radiologi	Tenant	4	Petugas radiologi

3. Daftar Permission (38 Permission Unik)

Seluruh permission dikelompokkan berdasarkan domain/modul bisnis RS:

Pasien (4)

Permission	Deskripsi
patient:create	Membuat data pasien baru
patient:read	Melihat data pasien
patient:update	Mengubah data pasien
patient:delete	Menghapus pasien (soft delete)

Pendaftaran & Antrian (5)

Permission	Deskripsi
registration:create	Membuat kunjungan baru
registration:read	Melihat daftar kunjungan
registration:update	Mengubah status kunjungan
registration:cancel	Membatalkan kunjungan
queue:manage	Mengelola antrian (panggil/selesai)

Jadwal (1)

Permission	Deskripsi
doctor-schedule:read	Melihat jadwal praktik dokter

Rekam Medis & Assessment (6)

Permission	Deskripsi
medical-record:create	Membuat rekam medis (SOAP)
medical-record:read	Melihat rekam medis
medical-record:update	Mengubah rekam medis draft
medical-record:finalize	Finalisasi rekam medis
assessment:create	Membuat pengkajian keperawatan
assessment:read	Melihat data pengkajian

Farmasi (6)

Permission	Deskripsi
pharmacy:read	Melihat data farmasi
pharmacy:manage	Mengelola dispensing obat
prescription:read	Melihat resep obat
prescription:create	Membuat resep (e-prescription)
stock:read	Melihat stok obat/barang
stock:manage	Kelola stok, mutasi, purchase order

Kasir & Billing (4)

Permission	Deskripsi
billing:read	Melihat tagihan pasien
billing:manage	Mengelola billing
payment:create	Memproses pembayaran
payment:read	Melihat riwayat pembayaran

Laboratorium (3)

Permission	Deskripsi
lab-order:read	Melihat order laboratorium
lab-result:create	Menginput hasil lab
lab-result:read	Melihat hasil laboratorium

Radiologi (3)

Permission	Deskripsi
radiology-order:read	Melihat order radiologi
radiology-result:create	Menginput hasil radiologi
radiology-result:read	Melihat hasil radiologi

Dashboard & Laporan (3)

Permission	Deskripsi
dashboard:read	Akses halaman dashboard
report:read	Melihat laporan
statistics:read	Melihat statistik

Administrasi (8)

Permission	Deskripsi
user:create	Menambah user baru
user:read	Melihat daftar user
user:update	Mengubah data user
user:delete	Menghapus user
tenant:manage	Mengelola profil tenant/RS
settings:manage	Mengelola pengaturan sistem
audit-log:read	Melihat audit log
admin:manage	Manajemen admin penuh

4. Matriks Akses Role × Permission

Tabel berikut menunjukkan permission yang dimiliki setiap role. Tanda ' = memiliki akses.

SA = Superadmin · AD = Admin · DK = Dokter · PR = Perawat · AP = Apoteker · KS = Kasir · PD = Pendaftaran · RM = Rekam Medis · MN = Manajemen · LB = Lab · RD = Radiologi

Grup	Permission	SA	AD	DK	PR	AP	KS	PD	RM	MN	LB	RD
	patient:create		'					'				
	patient:read		'	'	'	'	'	'	'	'	'	'
	patient:update		'	'	'			'				
	patient:delete		'									
	registration:create		'					'				
	registration:read		'					'	'	'		
	registration:update		'					'				
	registration:cancel		'					'				
	queue:manage		'					'				
Jadwal	doctor-schedule:read		'	'				'				
	medical-record:create		'	'								
	medical-record:read		'	'	'				'			
	medical-record:update		'	'					'			
	medical-record:finalize		'	'								
	assessment:create		'	'	'							
	assessment:read		'	'	'				'			
	pharmacy:read		'	'		'						
	pharmacy:manage		'			'						
	prescription:read		'	'	'	'						
	prescription:create		'	'								
	stock:read		'			'						
	stock:manage		'			'						
	billing:read		'				'			'		
	billing:manage		'				'					
	payment:create		'				'					
	payment:read		'				'			'		
	lab-order:read		'	'	'						'	
	lab-result:create		'								'	
	lab-result:read		'	'	'						'	
	radiology-order:read		'	'								'
	radiology-result:create		'									'
	radiology-result:read		'	'								'
	dashboard:read	'	'	'	'	'	'		'	'	'	'
	report:read	'	'							'		
	statistics:read	'	'							'		

Grup	Permission	SA	AD	DK	PR	AP	KS	PD	RM	MN	LB	RD
	user:create		'									
	user:read	'	'									
	user:update		'									
	user:delete		'									
	tenant:manage	'	'									
	settings:manage	'	'									
	audit-log:read	'	'									
	admin:manage		'									

5. Rincian Per Role — Menu & Fitur

5.1 Superadmin — SA Panel

Beroperasi di panel khusus (/sa/*). Sub-role: Owner (akses penuh) dan Operator (terbatas).

#	Halaman	Fungsi	Owner Only
1	/sa	Dashboard — metrik platform, statistik, revenue	—
2	/sa/registrations	Antrian pendaftaran RS baru	—
3	/sa/tenants	Daftar tenant, toggle aktif, hapus	—
4	/sa/tenants/[id]	Detail tenant: stats, users, subscription	—
5	/sa/payments	Verifikasi pembayaran	—
6	/sa/plans	Kelola paket langganan & transaksi	'
7	/sa/monitoring	Monitoring sistem & tenant	—
8	/sa/settings	12 pengaturan platform	'
9	/sa/super-admins	Kelola akun super admin	'
10	/sa/activity	Activity log	—

5.2 Admin RS — Akses Penuh (38 Permission)

Admin memiliki seluruh 38 permission dan mengakses semua halaman tenant:

Kategori	Halaman / Sub-menu
Dashboard	/dashboard — Overview lengkap semua modul
Pendaftaran	Daftar Baru + Kelola Antrian
IGD / Rawat Inap	/igd + /rawat-inap
Pasien	/pasien — CRUD, deteksi duplikasi NIK
Rekam Medis	SOAP, CPPT, Pengkajian, Resume, Consent, Edukasi
Farmasi (7 sub)	Resep, Stok, Alerts, Mutasi, PO, OTC, Stock Opname
BPJS (8 tab)	Peserta, SEP, Rujukan, PCare, e-Klaim, Aplicare, Monitoring, Antrol
Kasir / Keuangan	Billing + Jurnal, COA, Buku Besar, Neraca, Laba Rugi
Lab / Rad / Bedah	Order, hasil, operasi, tim bedah
MCU / Gizi	Medical Check Up + Nutrisi (5 tab)
Laporan	7 jenis + export XLSX/PDF/CSV
Kepegawaian	Pegawai, Jadwal, Absensi, Penggajian
Pengaturan (18)	Profil RS, Ruangan, Dokter, Asuransi, Pengguna, Audit, dll

5.3 Dokter — Fokus Klinis (17 Permission)

Fokus utama: rekam medis, diagnosa, resep, dan melihat hasil penunjang.

Menu	Hak Akses
Dashboard	Overview kunjungan hari ini
IGD / Rawat Inap	Pemeriksaan pasien, visite, discharge
Pasien	Lihat & update data pasien
Rekam Medis	Buat SOAP, CPPT, diagnosis ICD-10, finalisasi
Lab / Radiologi	Lihat order & hasil pemeriksaan (read-only)
Bedah	Jadwal & detail operasi, laporan post-op
MCU / Gizi	Input hasil MCU, konsultasi gizi
Logbook	Catatan tindakan pribadi

5.4 Perawat — Asistensi Klinis (9 Permission)

Fokus: pengkajian keperawatan dan asistensi rekam medis.

Menu	Hak Akses
Dashboard	Overview hari ini
IGD / Rawat Inap	Triage, monitoring pasien
Pasien	Lihat & update data pasien
Rekam Medis	Lihat RM (read-only), buat pengkajian keperawatan
MCU / Gizi	Input hasil MCU, skrining nutrisi pasien

5.5 Apoteker — Farmasi & Stok (7 Permission)

Menu	Hak Akses
Dashboard	Overview farmasi
Farmasi (7 sub)	Resep, Stok, Alerts, Mutasi, PO, OTC, Stock Opname
Gudang / CDSS	Gudang umum + Drug interaction checker

5.6 Kasir — Billing & Pembayaran (6 Permission)

Menu	Hak Akses
Dashboard	Overview kasir
BPJS / Kasir	SEP, billing, proses bayar, cetak kuitansi
Keuangan / OTC	Jurnal otomatis + penjualan obat bebas

5.7 Pendaftaran — Front Office (9 Permission)

Menu	Hak Akses
Dashboard	Overview antrian hari ini
Pendaftaran	Form pendaftaran + kelola antrian
IGD / Rawat Inap	Registrasi pasien IGD & rawat inap
Pasien / BPJS	CRUD pasien, cek peserta BPJS, buat SEP

5.8 Rekam Medis, Manajemen, Lab, Radiologi

Role dengan akses terbatas pada modul spesifik:

Role	Perm	Menu yang Dapat Diakses
rekam_medis	5	Dashboard, Pasien (lihat), Rekam Medis (lihat & edit, pengkajian)
manajemen	7	Dashboard, Keuangan (read-only), Laporan (7 jenis + export), Kepegawaian
lab	4	Dashboard, Laboratorium (terima sampel, proses, input hasil, finalisasi)
radiologi	4	Dashboard, Radiologi (proses, input bacaan & kesan, cetak hasil)

6. Security Guard: Frontend & Backend

6.1 Frontend Guard (Menu Filtering)

Setiap menu item di Next.js didefinisikan dengan array roles. Hook usePermissions() memfilter menu secara otomatis berdasarkan role user yang sedang login:

- MENU_ITEMS di packages/constants/src/menu-items.ts — setiap item punya roles: Role[]
- usePermissions() hook melakukan filterItems() berdasarkan role yang login
- Tenant subscription modules di-check via allowedModules (pembatasan per paket)
- SA Panel layout terpisah dengan flag ownerOnly per menu item

6.2 Backend Guard (RBAC Middleware)

Setiap route Express.js dilindungi oleh middleware bertingkat:

- authenticate — verifikasi JWT access token pada setiap request
- checkPermission(...perms) — cek role user vs required permission !' HTTP 403 jika ditolak
- tenantMiddleware — identifikasi tenant dari subdomain / header X-Tenant-Slug
- saIpWhitelist — IP whitelist khusus SA endpoints (dari platform_settings)
- Rate limiting — Redis-backed per tenant dan per endpoint

6.3 Alur Autentikasi & Session

- Login !' JWT Access Token (15 menit) + Refresh Token (dari session_timeout_minutes DB)
- MFA TOTP opsional; wajib untuk SA jika enforce_2fa_superadmin = true
- Session limit: max_concurrent_sessions dari platform_settings
- Token rotation: refresh token dirotasi setiap kali access token di-refresh
- Audit trail: semua akses data sensitif tercatat di tabel audit_logs
- Password hashing: bcrypt dengan salt rounds "e 12

Defense-in-depth: Frontend filtering + Backend middleware berjalan independen — keamanan berlapis.

7. Test Accounts — Tenant rs-demo

Berikut daftar lengkap 13 akun untuk testing. Seluruh 11 role sudah memiliki akun test.

7.1 Super Admin (Platform Level)

Nama	Email	Password	Sub-Role
Super Admin SIMRS	admin@simrs.id	Admin123!	Owner

7.2 Akun Tenant rs-demo (12 User)

URL Login: https://simrs.online/login · Tenant URL: https://rs-demo.simrs.online

#	Nama Lengkap	Email	Password	Role
1	Admin RS Demo	admin@rs-demo.simrs.id	Demo123!	admin
2	dr. Budi Santoso, Sp.PD	dr.budi@rs-demo.simrs.id	User123!	dokter
3	dr. Siti Rahayu, Sp.A	dr.siti@rs-demo.simrs.id	User123!	dokter
4	dr. Andi Wijaya	dr.andi@rs-demo.simrs.id	User123!	dokter
5	Dewi Lestari, S.Kep	perawat.dewi@rs-demo.simrs.id	User123!	perawat
6	Rina Wulandari, S.Farm	apoteker.rina@rs-demo.simrs.id	User123!	apoteker
7	Maya Putri	kasir.maya@rs-demo.simrs.id	User123!	kasir
8	Ahmad Fauzi	pendaftaran.ahmad@rs-demo.simrs.id	User123!	pendaftaran
9	Petugas Rekam Medis	rekammedis@rs-demo.simrs.id	User123!	rekam_medis
10	Pimpinan RS	manajemen@rs-demo.simrs.id	User123!	manajemen
11	Petugas Lab	lab@rs-demo.simrs.id	User123!	lab
12	Petugas Radiologi	radiologi@rs-demo.simrs.id	User123!	radiologi

Catatan: Akun #1 (Admin) password Demo123!, akun #2–12 password User123!.

7.3 Ringkasan Akses Per Akun

Akun (Role)	Menu yang Dapat Diakses
Admin RS Demo	SEMUA menu (35+ halaman) + 18 sub-pengaturan
Dokter (3 akun)	Dashboard, IGD, Ranap, Pasien, RM, Lab*, Rad*, Bedah, MCU, Gizi, Logbook
Perawat	Dashboard, IGD, Ranap, Pasien, RM*, MCU, Gizi
Apoteker	Dashboard, Farmasi (7 sub), Gudang, CDSS
Kasir	Dashboard, BPJS, Kasir, Keuangan, Farmasi-OTC
Pendaftaran	Dashboard, Pendaftaran, Antrian, IGD, Ranap, Pasien, BPJS
Rekam Medis	Dashboard, Pasien, Rekam Medis
Manajemen	Dashboard, Keuangan*, Laporan, Kepegawaian
Lab	Dashboard, Laboratorium
Radiologi	Dashboard, Radiologi

Keterangan: * = read-only (hanya dapat melihat, tidak dapat input/edit data)

Semua akun test sudah aktif dan siap digunakan. Login: https://simrs.online/login